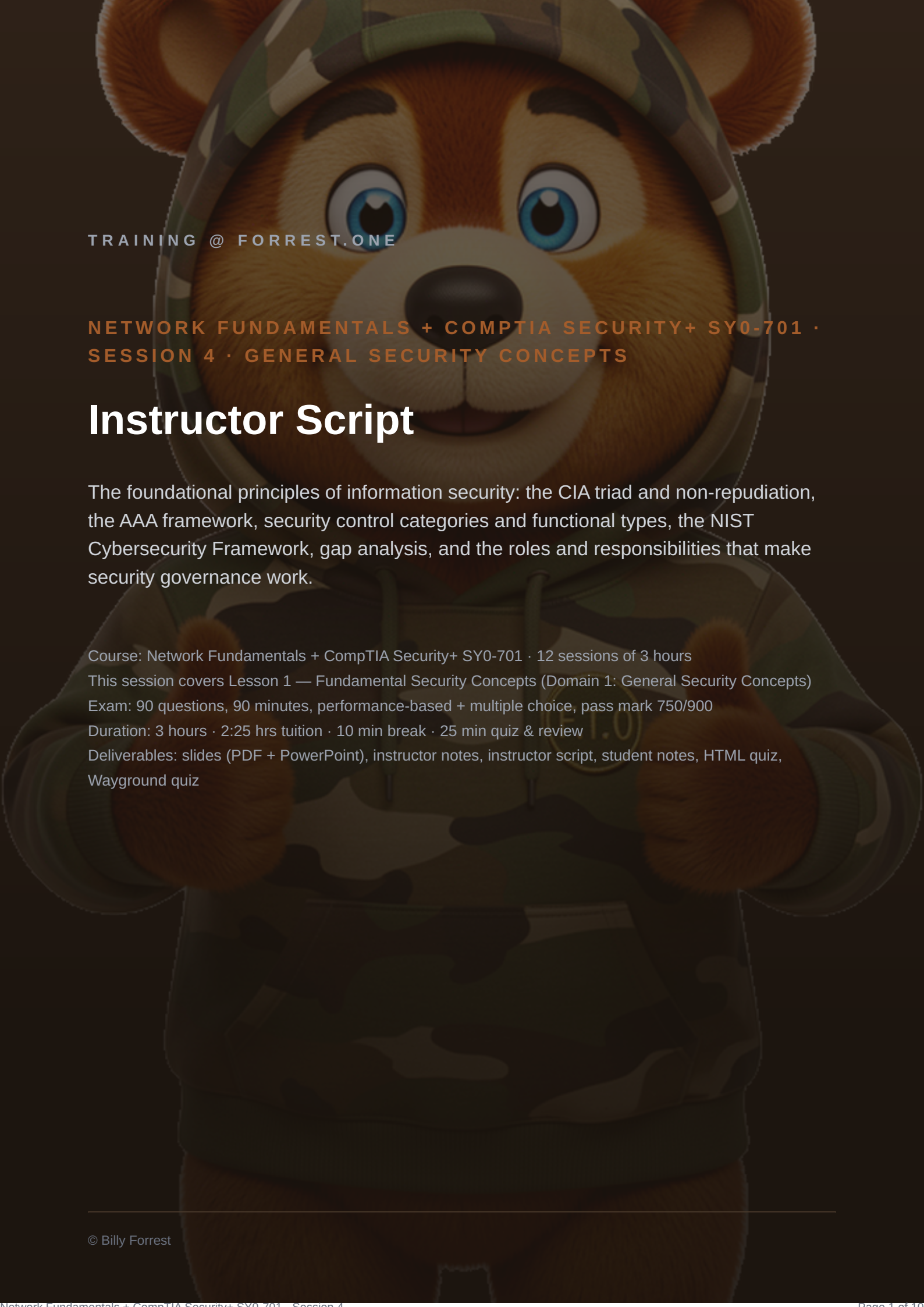




TRAINING @ FORREST.ONE

NETWORK FUNDAMENTALS + COMPTIA SECURITY+ SY0-701 ·
SESSION 4 · GENERAL SECURITY CONCEPTS

Instructor Script

The foundational principles of information security: the CIA triad and non-repudiation, the AAA framework, security control categories and functional types, the NIST Cybersecurity Framework, gap analysis, and the roles and responsibilities that make security governance work.

Course: Network Fundamentals + CompTIA Security+ SY0-701 · 12 sessions of 3 hours

This session covers Lesson 1 — Fundamental Security Concepts (Domain 1: General Security Concepts)

Exam: 90 questions, 90 minutes, performance-based + multiple choice, pass mark 750/900

Duration: 3 hours · 2:25 hrs tuition · 10 min break · 25 min quiz & review

Deliverables: slides (PDF + PowerPoint), instructor notes, instructor script, student notes, HTML quiz, Wayground quiz

Instructor Script — Fundamental Security Concepts

A word-for-word delivery script for Session 4, following the expanded session narrative chapter for chapter. Stage directions appear in square brackets. Each slide runs roughly 45–90 seconds of speech; activities and discussions expand the timings in the instructor notes.

Slide 1 · Title

Welcome to the Network Fundamentals + CompTIA Security+ SY0-701 course, twelve sessions that will take you from security fundamentals to exam readiness. This first session lays the foundation: the principles that every later session builds on. Confidentiality, integrity and availability; the AAA framework; security controls; frameworks, roles and change control. Get these right, and the rest of the course fits into place.

Slide 2 · The journey

Here is the shape of the course. Twelve sessions across the five exam domains: network foundation in sessions one to three, the Security+ core in four to seven, security architecture in eight and nine, and operations and governance in ten to twelve. The exam itself: ninety questions, ninety minutes, performance-based questions alongside multiple choice, and a pass mark of seven hundred and fifty on a scale to nine hundred.

Slide 3 · Session objectives

By the end of these three hours you will be able to explain why controls exist, classify any control by category and by functional type, define the CIA triad, explain non-repudiation and the three authentication factors, describe accounting and zero trust, explain deception and controlled change, apply the NIST Cybersecurity Framework, and name the key security roles. Eight objectives, and the quiz at the end tests every one.

Slide 4 · Why security controls exist

We start with the question the whole session answers: what actually stops an attack? Every organisation holds assets it must protect, and faces threats that will try to take them. Those threats are external, like a ransomware crew, and internal, like a trusted employee copying files. A control is any safeguard or countermeasure that manages that risk. Some controls prevent access, some detect activity, and some respond once something has gone wrong. Notice that controls are not only technical: policy, procedure and physical barriers all count. And controls reduce risk rather than remove it.

Slide 5 · The layered view: defence in depth

One control alone is never enough, and that is the idea behind defence in depth. Picture a firewall at the network edge. If an attacker slips past it, an intrusion detection system is still watching traffic. If that misses the activity, the logs hold the evidence. Each layer covers a weakness in the one before. Encryption protects the data, and policy governs how that data may be handled. Layers fail independently, and that independence is the point. Together they lower the likelihood and the impact of an incident.

Slide 6 · Technical controls

Now the categories, and category tells you how a control is delivered. Technical controls are built into systems, in hardware, in software, or in both together. A firewall stands between a trusted internal network and the untrusted internet, and it allows or blocks traffic against a rule set. Encryption makes intercepted data useless without the key. Access control lists name exactly which users or systems may reach a resource. An intrusion detection system watches traffic for signs of an attack. These controls enforce policy mechanically, with no person in the loop.

Slide 7 · Physical controls

Physical controls protect the premises, the hardware and the people. Locks are the oldest example, from a key to a card reader. Fences mark the perimeter and slow an intruder down. Cameras watch the area, and they deter as well as record. Then there is the mantrap, a small room with two doors, where only one door can open at a time. Biometric door access verifies a fingerprint or an iris before it releases a lock. In a data centre they guard the same assets that technical controls defend.

Slide 8 · Managerial controls

Managerial controls, which many organisations call administrative controls, are the policies and procedures that govern security. The first is the risk assessment. It identifies, evaluates and prioritises the risks facing an asset, so spending follows the real danger. Next comes policy: a formal document stating how information must be protected. Then training. A programme that teaches staff to spot a phishing email and report an incident is a control in its own right. Managerial controls set direction, and technical controls enforce it.

Slide 9 · Operational controls

Operational controls are the day-to-day work that makes policy real. A security guard walking the building is one: the patrol checks that doors are locked, cameras are working, and nobody unauthorised is present. Incident response procedures are another: identify the incident, contain the threat, eradicate the cause, recover the systems, then review what happened. Backup routines keep data recoverable when hardware fails or ransomware strikes, with copies held both on site and off site. Managerial controls write the policy, and operational controls carry it out.

Slide 10 · Preventive controls

That is the category axis complete. The second axis is the functional type, and it says what the control does. Preventive controls are proactive, and their job is to stop an incident before it starts. A firewall blocks traffic that the rules do not allow. Encryption converts data into a coded form, so a stolen copy cannot be read without the key. Security training is preventive too. Network segmentation is another: if a workstation is separated from the finance server, an infected machine cannot wander across the whole estate. Now the honest part: prevention is never perfect, so pair it with detection.

Slide 11 · Detective controls

Detective controls find what prevention missed. Log monitoring is the everyday example: security teams review system and network logs for unusual activity, such as failed logins at an odd time. An intrusion detection system goes further, comparing traffic against known attack signatures or spotting behaviour that does not fit the norm. A security audit is detective as well, because it evaluates whether the controls you believe in are actually working. A firewall blocks most intrusion attempts, and the logs plus the detector tell you about the ones that got through.

Slide 12 · Corrective controls

Corrective controls come after the event, and their aim is damage control. Consider ransomware that encrypts a file server. First you patch the vulnerability the attacker used, so the same door stays shut. Then you restore the data from backup, returning to a point before the incident. Then you review the procedures that failed and revise them. That last step is the one organisations skip, and it is the one that stops a repeat. Corrective controls are reactive by nature, and that is not a fault.

Slide 13 · Compensating controls

Compensating controls cover a gap. They are what you do when the proper control is not feasible. Take a legacy application that cannot perform encryption: you protect its traffic at the network layer with a secure gateway instead. A small business that cannot afford an intrusion detection system might compensate with enhanced logging and frequent audits. Where production cannot be interrupted, you add cameras and guarding. A compensating control is temporary by intent, so it must be documented, reviewed, and replaced once the proper control becomes possible.

Slide 14 · Deterrent controls

Deterrent controls work on the attacker's mind rather than on the traffic. They do not stop an attack, and that is the point to hold on to. They make an attempt feel too risky to bother with. A warning banner is the classic example: a message stating that unauthorised access is prohibited and may be prosecuted tells an opportunist that the consequences are real. Visible cameras do the same work, because a recording shifts the odds of being caught. Deterrence succeeds when the attacker believes detection is likely, and it fails against an attacker who does not care.

Slide 15 · Directive controls

Directive controls point inwards, at your own people. They set out how work must be done, so that security is not left to individual judgement. The acceptable use policy is the clearest example: it states what is allowed on company systems and what is forbidden. Security procedures carry the same weight at a lower level, describing the safe way to handle sensitive data, and the encryption required before anything is sent outside. Directive controls are how a security culture is built, in writing, one expectation at a time.

Slide 16 · Activity: classify the controls

[Run the activity per the instructor notes. 8 minutes in pairs, 4 minutes debrief.] A firewall blocking unauthorised ports: technical and preventive. A security camera over the server room door: physical and deterrent. An intrusion detection system watching traffic: technical and detective. A backup-and-restore plan after ransomware: operational and corrective. A secure gateway protecting a legacy system that cannot encrypt: compensating. Now add one control from your own workplace to each category. Category first, then type. Two axes every time.

Slide 17 · The CIA triad

Now the triad that underpins everything else. Confidentiality means information is only disclosed to those with the right permission. Integrity means the data is accurate, complete, and has not been changed without authorisation. Availability means authorised users can reach the systems and data when they need them. Here is how to use it in practice: when you meet a control, ask which pillar it serves. Encryption and access control serve confidentiality, hashing and signatures serve integrity, and redundancy serves availability. And the three often pull against each other.

Slide 18 · Threats and controls by pillar

Let us make the triad concrete with threats and the controls that answer them. Confidentiality is attacked by a data breach or by eavesdropping on traffic, and the answers are encryption plus strong authentication. Integrity falls to tampering, to a man in the middle who alters data in flight; the answers are cryptographic hashes, digital signatures, and version control that lets you roll back. Availability is attacked by denial of service, by hardware failure, and by disasters such as fire or flood. Redundancy, failover and tested backups are the reply. And insider misuse touches all three pillars, which is why least privilege, monitoring and audit trails sit alongside.

Slide 19 · Non-repudiation

Non-repudiation is the guarantee that nobody can deny an action later. It gives proof of origin, so a sender cannot deny the message. The mechanism is the digital signature. The sender creates a hash of the message, then encrypts that hash with their private key. Anyone can decrypt the signature with the matching public key and verify it. If the two agree, the message is intact, and only that private key could have signed it. Audit logs and timestamps finish the job, by proving who acted and exactly when.

Slide 20 · Analyst's lens: why denial must fail

Why does this matter beyond the exam? Think about an electronically signed contract. If either party could later deny signing it, the agreement would be worthless and no court could resolve the dispute. The same applies to a payment: a bank must prove that the account holder authorised the transfer, and a signature plus an audit trail does exactly that. Regulation often demands it too. Healthcare rules in the United States require mechanisms that provide non-repudiation, so patient records carry proof of who accessed and changed them.

Slide 21 · Authentication: the three factors

Authentication answers one question: whether a person really is who they claim to be. There are three classic factors. Something you know, such as a password or a personal identification number, or pin. Something you have, such as a token, a smart card, or an application on a phone. And something you are, which is a biometric, such as a fingerprint or an iris. Multifactor authentication requires two or more different factors. Two passwords are not multifactor. Attackers go for the weakest factor, so add a second.

Slide 22 · Factors, examples and weaknesses

Each factor has a weakness, and knowing them shapes your design. A password can be reused, phished or guessed by brute force. Something you have can be lost or stolen. Biometrics resist copying, though they can be spoofed, and they raise privacy questions. You will also meet the protocols. Kerberos provides strong authentication in many enterprises. The Lightweight Directory Access Protocol, or LDAP, looks up directory accounts. The Security Assertion Markup Language, or SAML, passes identity between systems, and single sign-on, or SSO, opens many applications with one login. Pick the protocol that fits.

Slide 23 · Discussion

[Run the discussion per the instructor notes.] Which pillar of the CIA triad fails first in a typical data breach? [Work through examples.] Stolen credentials hit confidentiality first, data is read. Then integrity, data is altered. Then availability, systems are locked or destroyed. Real incidents chain across pillars; that is why the triad is a triad, not three separate problems.

Slide 24 · Break

Ten minutes. When we return: accounting and audit trails, then zero trust, deception and change control.

Slide 25 · Accounting and audit trails

Accounting is the third letter of the triple A framework. It means recording user activity and resource use, such as logins and configuration changes. The output is the audit trail, a chronological record that traces an action back to a specific user. Why does that matter? First, accountability: when people know their actions are recorded, behaviour improves, and when it does not, you can prove who acted. Second, investigation: after a

breach, the audit trail lets you reconstruct events, find the root cause, and measure how far the attacker reached. It also demonstrates compliance during an audit, and it reveals policy violations nothing else would catch.

Slide 26 · Log management

Audit trails only help if you can actually find things in them. That is log management. First, centralise: pull the logs from servers, firewalls, endpoints and applications into one repository, so you can correlate an event across systems. Second, set a retention period: keep the data long enough to satisfy regulation and your own investigations. Third, analyse. That is where a Security Information and Event Management platform, or SIEM, earns its place, collecting events and flagging the suspicious ones with automated alerting. A log nobody reads is evidence you will not have.

Slide 27 · Zero trust: never trust, always verify

Zero Trust Architecture starts from an uncomfortable assumption: threats exist inside the network as well as outside it. The old model trusted anything inside the perimeter, and that failed, because insiders, stolen credentials and cloud services all move across the line. So zero trust removes implicit trust altogether. No user and no device is trusted by default. Every request is authenticated and authorised before it reaches a resource. Microsegmentation divides the network into isolated zones, so an attacker cannot move sideways without meeting another check. And the exam line: zero trust is a design principle, not a product.

Slide 28 · Continuous verification and least privilege

The second principle is continuous verification. Logging in once does not earn lasting trust. The system keeps watching through real-time analytics, machine learning and adaptive authentication, and it adjusts policy when behaviour changes. A sign-in from an unfamiliar country at an unusual time prompts another check. The third principle is least privilege, so users receive only the access their role requires. Zero trust is complex, costly and culturally difficult, because constant verification feels inconvenient. The payoffs are less lateral movement and far better visibility.

Slide 29 · Honeypots, honeynets and honeytokens

Deception technologies mislead an attacker deliberately. A honeypot is a decoy system that looks like a real server, with services that appear to be genuine targets. An attacker who engages it reveals method, tooling and intent. A honeynet takes that further, building a whole decoy network with several systems. A honeytoken is a single piece of fake data, such as a bogus account or a planted file; it raises an alert the moment somebody touches it. Watch for the tell: no legitimate user should ever reach these.

Slide 30 · What deception buys you

What does deception actually buy you? Three things. The first is early warning: because a decoy sits beside production, any contact is suspicious by definition, so you learn about a campaign before it reaches anything

that matters. The second is threat intelligence: everything the attacker does on a honeypot is recorded, so you can study the tools, the technique and the target they wanted. The third is resource waste: every moment an intruder spends on a decoy is a moment not spent on real systems.

Slide 31 · A controlled change, step by step

Now change management, which is where a great many real incidents begin. An unmanaged change can open a back door, disable a control, or break a dependency. The process has four steps and one habit. First, submit a request, stating what will change, why, and what benefit is expected. Second, assess the impact on security, functionality and performance, and identify the risks it brings. Third, obtain approval from the people who own the system, often including a security officer. Fourth, schedule the work in a maintenance window, with a rollback plan ready in case it goes wrong. The habit is documentation: record every change, however minor it looks.

Slide 32 · When change management is skipped

What happens when the process is skipped? Consider an unauthorised firewall rule change. One small edit can expose a sensitive internal service to the internet, and nobody knows it is there. Installing unapproved software is just as dangerous, because it brings malware or compatibility problems. The silent risk is configuration drift, where systems wander away from the approved baseline. Once that happens, nobody can say with confidence what a normal build looks like, and incident response slows down.

Slide 33 · What a change can break

Every change has technical consequences, and four account for most trouble. The first is the allow list, which permits only pre-approved applications, so a new one must be added or it fails. The second is firewall rules: a new server needs a rule, and a rule written in a hurry is how an open port appears where it should not. The third is the security baseline, the minimum standard every build must meet. And a protocol that becomes deprecated means the baseline itself must change. The fourth is dependencies, where one upgrade breaks what relies on it. Evaluate all four before anything is deployed.

Slide 34 · Before you approve: evaluate the impact

Two habits make all of this manageable. The first is to test in a non-production environment: a realistic test shows how the change interacts with the controls already in place. The second is to evaluate security impact before you approve anything, not after. Ask what existing controls the change affects, and what new risk it introduces. Then write the rollback plan, with backup procedures, restoration steps and a way to verify the system is healthy again. A change without a way back is a gamble, not a project.

Slide 35 · The NIST Cybersecurity Framework

Frameworks give security a common map. The NIST Cybersecurity Framework has five functions. Identify: know your assets, systems and risks. Protect: implement safeguards for critical services. Detect: find security

events quickly. Respond: contain and mitigate incidents. And Recover: restore capabilities and learn. Identify, protect, detect, respond, recover, the lifecycle of security. Note that CSF 2.0 adds a sixth function, Govern, but the exam expects the core five.

Slide 36 · Gap analysis

How do you know where you stand? Gap analysis compares your current security posture against a target framework. It finds missing controls, weak areas and unmeasured functions. The output is a scored view, say fifty percent maturity in a function. The value is prioritised, evidence-based improvement: you know what to fix first, and you can measure progress. Remember the distinction the quiz tests: a scan finds technical holes in systems; a gap analysis measures the whole programme against a framework.

Slide 37 · Core security principles

Four principles shape secure design. Defence in depth: layered controls, so no single point of failure, and one layer failing does not mean the asset falls. Least privilege: users get only the access they need, reviewed regularly. Separation of duties: no one person controls a critical process alone, which is why one person should not both raise and approve a payment. And zero trust: never trust implicitly, verify every request. Each principle limits the blast radius of a single failure.

Slide 38 · Who does what

Security is a team sport. The CISO, or Chief Security Officer, owns security strategy and risk at executive level. The Information Systems Security Officer manages day-to-day security systems and compliance. The data owner is accountable for a data set's classification and protection. The data custodian implements the controls that protect it. The security analyst monitors, triages and responds. The auditor reviews controls independently. Notice the pattern: owners are accountable, custodians implement, auditors verify.

Slide 39 · What this maps to in the exam

Quick alignment with the paper. Objective 1.1: security concepts, the triad, non-repudiation, AAA and gap analysis. Objective 1.2: security controls, categories and functional types. Objective 1.3: security principles, defence in depth, least privilege, separation of duties and zero trust. Objective 1.4: roles and responsibilities. Four objectives, and we have covered every one. When a question names a control, classify the category first, then the functional type.

Slide 40 · Quiz

[Direct candidates to [Quiz_Session_04.html](#). 15 minutes.] Open the session quiz. Twenty questions, immediate feedback, and every question is tagged with the exam objective it tests. Read every explanation; the distractors teach as much as the answers. Aim for seventy percent or better before you leave today.

Slide 41 · Key takeaways

Seven takeaways. One: controls are safeguards that reduce risk, and they work in layers. Two: category says how, technical, physical, managerial and operational. Three: type says what, preventive, detective, corrective, compensating, deterrent and directive. Four: confidentiality, integrity and availability anchor every decision, with non-repudiation making a signed action provable. Five: authentication proves identity, accounting records activity. Six: zero trust verifies every request instead of trusting a network location. Seven: deception turns an attacker into a teacher, and change control keeps systems on the approved baseline.

Slide 42 · Revision checklist

Before next session: retake the quiz until you score seventy percent without guessing. Classify ten controls, five by category and five by functional type. Map your workplace: one control for each category and each type. Practise the triad by classifying five recent incidents by pillar. And read ahead to Session 5, where we meet the threat actors: threat types, threat actors and attack vectors.

Slide 43 · Next session preview

Next time, Threats, Attack Types and Threat Actors. We will compare the different threat actor types and what motivates each of them, from the opportunist to the well-funded group. We will look at attack vectors and attack surfaces, and how an entry point becomes an intrusion. And we will work through the relationship between vulnerability, threat and risk, which is the reasoning behind every control you have just classified. Take the quiz, revise the six control types, and I will see you in Session Five.